



LAPORAN

Investigasi Forensik Digital [Wazuh Lab]

Bootcamp Cyber Security Batch [5]

Disusun oleh: Dimas Jayusman

[Mei 2026]

DAFTAR ISI

DAFTAR ISI	2
DAFTAR GAMBAR.....	3
DAFTAR TABEL	4
I. EXECUTIVE SUMMARY	5
1.1 Latar Belakang	5
1.2 Artefak Barang Bukti.....	5
1.3 Temuan	6
1.4 Timeline	8
II. PEMBAHASAN.....	10
2.1 Ruang Lingkup Analisis	10
2.2 Analisis Server.....	11
2.3 Analisis Kerentanan Aplikasi.....	12
2.4 Penilaian Risiko (Risk Assessment).....	13
2.5 Analisis Aktivitas Pasca-Eksploitasi	15
III. KESIMPULAN DAN SARAN.....	17
3.1 Kesimpulan.....	17
3.2 Saran.....	17
LAMPIRAN	19
Lampiran 1. Log Aktivitas Brute Force	19
Lampiran 2. Web Vulneability Scanning / RCE.....	20
Lampiran 3. Fuzzing	22
Lampiran 4. MySql general query log	23
Lampiran 5. Status Firewall UFW	24
Lampiran 6. Harcoded Credential	25
Lampiran 7 SAST Report.....	26
REFERENSI	27

DAFTAR GAMBAR

Figure 1. ssh_brute_force.....	19
Figure 2. web_scan_rce	21
Figure 3. mysql_general_log	23
Figure 4. Status Firewall UFW	24
Figure 5. Harcoded Credential	25

DAFTAR TABEL

Table 1. Ringkasan Temuan Investigasi	7
Table 2. Timeline Insiden	9
Table 3. Daftar artefak digital yang menjadi ruang lingkup analisis	11
Table 4. Penilaian Risiko dan Severity Temuan	15

.

I. EXECUTIVE SUMMARY

1.1 Latar Belakang

Investigasi forensik digital dan asesmen keamanan ini dilakukan terhadap server *production* aplikasi e-commerce `dibishop.duckdns.org`. Investigasi ini dipicu oleh indikasi serangan aktif dari pihak eksternal, yang ditandai dengan lonjakan aktivitas tebak sandi (*brute-force*) pada layanan SSH serta percobaan eksploitasi kerentanan aplikasi web jarak jauh (seperti LFI dan RCE).

Aplikasi web yang menjadi target serangan terbukti memiliki postur keamanan yang sangat lemah. Insiden difasilitasi oleh kegagalan arsitektur pertahanan berlapis (*Defense in Depth*), mulai dari matinya *host-based firewall* (UFW), kebocoran kredensial *database* secara *plaintext*, hingga masifnya kerentanan pada *source code* (puluhan titik SQL Injection dan XSS). Kondisi ini secara langsung membuka jalan bagi ancaman pencurian data massal (*Data Breach*) dan pengambilalihan kendali server (*Server Takeover*).

Untuk membedah insiden secara komprehensif, investigasi ini mengandalkan beberapa sumber log dan artefak utama:

- **SIEM Log:** Menggunakan Wazuh untuk mengidentifikasi indikator kompromi (IoC), melacak jejak intrusi jaringan, *fuzzing* direktori, dan serangan *brute-force* dari IP asing (Vietnam, Meksiko, AS).
- **Server & System Log:** Pemeriksaan konfigurasi kritikal pada sistem operasi dan *web server* (status UFW, Fail2ban, `/etc/ssh/sshd_config`, Apache, dan PHP).
- **Database Log:** Pemeriksaan miskonfigurasi privasi pada `/var/lib/mysql/srv974671.log` yang merekam aktivitas *query* pelanggan secara *plaintext*.
- **Application Vulnerability Report:** Mengingat tidak ditemukannya *file executable malware* biner, analisis dialihkan pada pemindaian keamanan statis (SAST) dan tinjauan *source code* manual untuk memetakan kerentanan aplikasi yang menjadi vektor masuk penyerang.

1.2 Artefak Barang Bukti

Daftar dan deskripsi artefak digital otentik yang dikumpulkan dan diekstraksi secara langsung dari infrastruktur target (`dibishop.duckdns.org`) untuk keperluan analisis forensik

dan audit keamanan.

List bukti digital yang digunakan dalam investigasi ini:

- **SIEM Wazuh Logs:** Rekaman log keamanan terpusat yang digunakan untuk menganalisis jejak intrusi jaringan, mencakup *alert* spesifik terkait aktivitas *Directory Fuzzing*, *SSH Brute-Force*, dan percobaan eksploitasi web jarak jauh (LFI/RCE).
- **File Konfigurasi Sistem & Server:** Berkas konfigurasi layanan yang diekstrak melalui terminal untuk mengevaluasi postur *Defense in Depth*, meliputi */etc/ufw/ufw.conf* (status *firewall*), */etc/ssh/sshd_config* (aturan otentikasi), */etc/apache2/* (konfigurasi *Directory Listing*), dan parameter keamanan pada */etc/php/*.
- **Log Database MySQL:** Artefak fisik berupa *file* */var/lib/mysql/srv974671.log* yang terekstraksi akibat menyalanya fitur *General Query Log*, berisi rekaman seluruh aktivitas *query* dan otentikasi pengguna secara *plaintext*.
- **Source Code Aplikasi (Web Root):** Artefak *file* pada direktori */var/www/dibimbingshop/*, secara spesifik berfokus pada *file* koneksi *db.php* yang menyimpan kredensial *hardcoded* dan folder repositori *.git* yang terekspos.
- **Dokumen Laporan SAST:** Laporan hasil pengujian keamanan aplikasi statis ([SAST Report Dibimbing-Shop](#)) tertanggal 24 Mei 2026 yang memvalidasi secara definitif keberadaan kerentanan *source code* (seperti SQL Injection dan Cross-Site Scripting).

1.3 Temuan

Ringkasan hasil utama dari analisis forensik, termasuk indikasi serangan, jenis ancaman, dan sistem yang terdampak.

No	Jenis Temuan	Keterangan
1.	Active Attacks (Intrusi Jaringan)	Aktivitas <i>SSH Brute-Force</i> dan percobaan eksploitasi <i>RCE/LFI</i> dari IP asing.

2.	Application Vulnerabilities	Ditemukan 52 kerentanan SQL Injection (SQLi) dan puluhan celah XSS/IDOR pada <i>source code</i> .
3.	Compromised Credentials	Kredensial <i>database</i> tertulis secara <i>hardcoded (plaintext)</i> di dalam <i>file db.php</i> .
4.	Ketiadaan Kontrol Keamanan	<i>Host-based firewall</i> (UFW) dalam keadaan mati dan Fail2ban tidak terinstal.
5.	Pelanggaran Privasi & Log	MySQL <i>General Query Log</i> aktif, merekam otentikasi <i>plaintext</i> pengguna.
6.	Sensitive Data Exposure	Direktori repositori <i>.git</i> dan <i>file</i> <i>dibimbingshop.sql</i> terekspos bebas di area publik.

Table 1. Ringkasan Temuan Investigasi

Berikut merupakan rincian temuan kritikal dari investigasi pada infrastruktur *dibishop.duckdns.org*:

- Kerentanan Kritis pada Source Code Aplikasi** a. Terdapat 52 titik kerentanan *SQL Injection* (CWE-89) dan puluhan celah *Cross-Site Scripting* (CWE-79) yang terdeteksi melalui pemindaian SAST. b. Ditemukan 1 kerentanan *Stored XSS* pada input pengguna berdasarkan hasil pengujian manual. c. Kerentanan ini memungkinkan eksekusi perintah jarak jauh ke *database* dan manipulasi data sesi (*session hijacking*).
- Kredensial Database Terbuka (Hardcoded)** a. Ditemukan *username* (*dibimbing-shop*) dan *password* (*password*) yang tertulis murni (*plaintext*) pada fungsi koneksi di */includes/db.php*. b. Pengujian terminal memvalidasi bahwa kredensial tersebut aktif dan memberikan akses penuh ke seluruh struktur tabel internal *e-commerce*.
- Indikasi Serangan Aktif Eksternal (Active Attacks)** a. Terekam aktivitas serangan penembakan sandi (*SSH Brute-Force*) secara masif oleh IP Vietnam (27.79.44.33 & 27.79.7.61). b. Terekam aktivitas *scanner* yang mencoba mengeksploitasi celah *Remote Code Execution* (RCE) menggunakan *payload* *pearcmd.php* oleh IP asal Meksiko (200.23.126.85).

4. **Ketiadaan Kontrol Keamanan Dasar (*Missing Security Controls*)** a. Layanan *firewall* bawaan tingkat sistem operasi (UFW) ditemukan dalam status tidak aktif (ENABLED=no). b. Mekanisme perlindungan *anti-brute-force* (Fail2ban) tidak terinstal di *server*, sehingga serangan dari luar tidak dapat diblokir secara otomatis.

1.4 Timeline

Garis waktu kronologis kejadian, berdasarkan korelasi bukti digital dari log SIEM Wazuh dan hasil ekstraksi konfigurasi dari server *dibishop.duckdns.org* hingga masa pengamatan akhir pada 24 Mei 2026.

Time-based incident timeline:

- **Initial Detection:** Terdeteksi pemindaian pasif dan *fuzzing* direktori oleh IP asing untuk mencari *file* konfigurasi web yang terekspos.
- **Escalation:** Eskalasi ancaman berupa serangan *brute-force* masif pada layanan SSH (mengincar otentikasi *root*) yang tidak terhalang oleh *firewall*.
- **Web Exploitation Attempt:** Percobaan injeksi *payload Remote Code Execution* (RCE) via LFI (fase ini menggantikan *malware drop*, karena penyerang mencoba mengeksploitasi web sebelum berhasil menanamkan *backdoor*).
- **Credential & Privacy Exposure:** Investigasi internal menemukan tereksposnya *hardcoded password* secara statis dan terekamnya log aktivitas otentikasi *database* dalam format *plaintext* di sistem.
- **Containment:** Audit forensik dan keamanan kode statis (SAST) dieksekusi secara penuh untuk merumuskan langkah mitigasi (*hardening*).

Tanggal	Kejadian
24 Mei 2026	<i>Initial Detection:</i> IP 64.23.189.99 (AS) memulai aktivitas <i>Directory Fuzzing</i> dan enumerasi untuk mencari <i>file</i> tersembunyi (seperti <i>.git</i>).

24 Mei 2026	<i>Escalation:</i> Serangan <i>brute-force</i> SSH bertubi-tubi dari IP 27.79.44.33 & 27.79.7.61 (Vietnam). Serangan masuk tanpa hambatan karena layanan UFW dan Fail2ban berstatus tidak aktif.
24 Mei 2026	<i>Exploitation Attempt:</i> IP 200.23.126.85 (Meksiko) meluncurkan serangan <i>Web Vulnerability Scanning</i> , mencoba mengeksekusi kerentanan LFI/RCE menggunakan <i>payload</i> pearcmd.php.
24 Mei 2026	<i>Internal Audit:</i> Investigasi menemukan miskonfigurasi fatal pada MySQL di mana variabel <i>General Query Log</i> aktif, serta ditemukannya <i>password plaintext</i> di dalam /includes/db.php.
24 Mei 2026	<i>Containment:</i> Pemindaian SAST dieksekusi. Laporan mengonfirmasi adanya 84 kerentanan <i>source code</i> (termasuk 52 celah SQLi tingkat <i>Critical</i>).

Table 2. Timeline Insiden

II. PEMBAHASAN

2.1 Ruang Lingkup Analisis

Proses forensik digital dan audit keamanan yang dilakukan terhadap insiden siber pada infrastruktur e-commerce dibishop.duckdns.org mencakup kegiatan identifikasi, akuisisi, analisis, dan dokumentasi terhadap berbagai artefak digital yang relevan. Ruang lingkup ini dirancang untuk menjawab pertanyaan utama: bagaimana penyerang berupaya mengeksploitasi sistem, di mana letak kelemahan arsitektur, dan aset apa saja yang terdampak.

Adapun batasan dan pendekatan dalam investigasi ini meliputi elemen berikut:

- **Rules of Engagement & Scoping:** Investigasi difokuskan secara eksklusif pada *endpoint* server web dan *database* dibishop.duckdns.org. Analisis mencakup rentang waktu log yang direkam hingga tanggal 24 Mei 2026.
- **Jenis Ancaman yang Dianalisis:** Investigasi membedah vektor ancaman intrusi jaringan (SSH *Brute-Force*), pemindaian kerentanan web jarak jauh (LFI/RCE), kerentanan *source code* (SQL Injection dan XSS), serta celah miskonfigurasi server (kredensial *hardcoded*, ketiadaan *firewall*, dan pelanggaran privasi log).
- **Tools:** Analisis menggunakan SIEM Wazuh (untuk korelasi *event* jaringan dan sistem), Terminal Linux/SSH (untuk ekstraksi log manual dan peninjauan konfigurasi *host*), serta *Static Application Security Testing* / SAST (untuk pemindaian *source code* aplikasi PHP).
- **Alert Awal dari SIEM:** Investigasi dipicu oleh *alert* dengan tingkat keparahan tinggi di Wazuh, khususnya terkait rentetan otentikasi SSH yang gagal dari IP asing serta deteksi *payload* berbahaya (seperti *pearcmd.php*) pada *request* HTTP.

Detail perangkat dan dokumen yang menjadi ruang lingkup dalam aktivitas investigasi forensik digital ini dijabarkan pada tabel berikut:

No	Nama Perangkat / Dokumen	Detail Artefak	Keterangan
	Server dibishop.duckdns.org	Konfigurasi Host Source Code Aplikasi	Ekstraksi konfigurasi UFW, SSH (<i>sshd_config</i>), Apache, dan PHP. Analisis celah pada <i>/var/www/dibimbingshop/</i> dan <i>db.php</i> .

	Dokumen Log Sistem	Wazuh SIEM JSON	Log <i>authentication_failed</i> dan <i>web vulnerability scanning</i> .
		MySQL Log File	Akuisisi log /var/lib/mysql/srv974671.log (berisi rekaman <i>plaintext</i>)
		Laporan SAST	Dokumen laporan pemindaian kerentanan statis aplikasi (CWE-89, CWE-79).

Table 3. Daftar artefak digital yang menjadi ruang lingkup analisis

2.2 Analisis Server

Pemeriksaan komprehensif terhadap konfigurasi sistem operasi, parameter layanan web, dan log aktivitas pada server `duckdns.org` yang menjadi target serangan keamanan.

Timeline Serangan & Korelasi Event (SIEM Wazuh) Ketidadaan lapis pertahanan dasar (*host-based firewall*) memicu rentetan serangan aktif secara berurutan:

- *Korelasi Event*: Miskonfigurasi Firewall (UFW Mati) → Web Fuzzing/Enumerasi (IP AS) → Percobaan Eksploitasi RCE/LFI web (IP Meksiko) → Serangan SSH Brute-Force masif (IP Vietnam).

A. Log & Artefak Server Penting Investigasi ini tidak hanya bergantung pada satu jenis log, melainkan menggabungkan beberapa sumber kritis di dalam server:

- **auth.log / Wazuh Alert**: Mencatat ribuan percobaan *login* SSH yang gagal (*authentication_failed*) dari IP 27.79.44.33 dan 27.79.7.61.
- **web server access log**: Mencatat jejak *request* anomali yang mengandung *payload* injeksi `pearcmd.php` dan `eval-stdin.php` dari IP 200.23.126.85.
- **Database Log (/var/lib/mysql/srv974671.log)**: Artefak kritikal yang membuktikan fitur *General Query Log* MySQL dalam keadaan aktif (ON), merekam lalu lintas data pelanggan dan otentikasi secara *plaintext*.
- **System Config (/etc/ufw/ufw.conf & /etc/ssh/sshd_config)**: Membuktikan bahwa `ENABLED=no` pada UFW dan `PermitRootLogin yes` pada SSH adalah akar penyebab *server* terekspos ke publik.

B. Analisis Aktivitas & Pola Ancaman

- **Apa pola aktivitasnya?** Pola aktivitas didominasi oleh serangan otomatis (botnet/scanner) yang melakukan pemindaian massal terhadap *port* 22 (SSH) dan *port* 80/443 (Web) tanpa adanya teknik penghindaran deteksi (*evasion*), memanfaatkan absennya Fail2ban.
- **Bagaimana privilege berubah?** Meskipun penyerang belum berhasil mengubah *privilege* secara langsung di level sistem operasi, konfigurasi SSH yang mengizinkan *login* root secara langsung dengan kata sandi (bukan *key-based*) memberikan jalur pintas bagi penyerang untuk langsung mendapatkan hak akses tertinggi tanpa perlu teknik *Privilege Escalation* lanjutan.
- **Apa yang dilakukan attacker setelah masuk?** Saat ini penyerang masih di tahap *Initial Access*. Namun, karena tereksposnya *file* konfigurasi *db.php* yang menyimpan kredensial *database* secara *hardcoded* dan menyalanya log *plaintext* MySQL, penyerang yang berhasil masuk dipastikan dapat langsung mengekstrak seluruh isi *database* (*Data Exfiltration*) tanpa perlawanan.

C. Korelasi Komprehensif (SIEM & Konfigurasi)

- **SIEM Alert → Why?:** Lonjakan *alert* "Authentication Failed" dan "Web Vulnerability Scanning" di Wazuh terjadi karena *server* kehilangan perimeter pertahanan utamanya. UFW tidak memblokir IP asing, dan ketiadaan Fail2ban membuat serangan *brute-force* bisa dilakukan secara persisten.
- **SIEM Correlated Event Chain:** Wazuh Network Alert (Serangan Jaringan) → Exposed System Configuration (UFW Mati & SSH Terbuka) → Vulnerable Source Code (Celah SQLi & XSS di aplikasi PHP).
- **MITRE ATT&CK Mapping:**
 - **T1595 (Active Scanning):** *Fuzzing* direktori web (IP AS).
 - **T1110 (Brute Force):** Penebakan kredensial SSH secara masif (IP Vietnam).
 - **T1190 (Exploit Public-Facing Application):** Percobaan eksekusi LFI/RCE pada *endpoint* aplikasi e-commerce (IP Meksiko).
 - **T1552 (Unsecured Credentials):** Kredensial *database* tersimpan sebagai *plaintext* di kode aplikasi (*db.php*).

2.3 Analisis Kerentanan Aplikasi

Identifikasi dan analisis terhadap kerentanan kritis pada *source code* aplikasi yang menjadi vektor utama ancaman, termasuk metode eksploitasi dan potensi dampaknya terhadap integritas data.

Karena tidak ditemukan aktivitas *malware* biner pada *server*, fokus analisis dialihkan pada kerentanan aplikasi yang memungkinkan penyerang melakukan eksekusi perintah jarak jauh (*Remote Code Execution*) dan manipulasi *database* secara tidak sah. Berdasarkan hasil pemindaian SAST dan audit manual, ditemukan pola eksploitasi sebagai berikut:

- **Vektor Serangan SQL Injection (SQLi):**
 - Ditemukan 52 temuan kritis (CWE-89) di mana aplikasi gagal melakukan sanitasi masukan (*unsanitized external input*) pada fungsi `mysqli_query`.
 - Contoh kerentanan terdapat pada `admin_area/edit_contact_us.php` baris 148, di mana data dari pengguna dimasukkan langsung ke *statement* SQL.
 - Metode eksploitasi: Penyerang dapat menyuntikkan *payload* SQL nakal untuk melakukan ekstraksi data pelanggan, menghapus tabel, atau melewati mekanisme otentikasi.
- **Vektor Serangan Cross-Site Scripting (XSS):**
 - Ditemukan 30 temuan tingkat tinggi (CWE-79) terkait input pengguna yang dicetak langsung ke dalam respons HTTP melalui fungsi `echo` tanpa *encoding* yang memadai.
 - Contoh kerentanan terdapat pada `edit_contact_us.php` baris 180.
 - Metode eksploitasi: Penyerang dapat menanamkan skrip JavaScript berbahaya untuk mencuri *session cookie* pengguna atau melakukan manipulasi konten halaman web secara *persistent* (Stored XSS).
- **Insecure Direct Object Reference (IDOR):**
 - Ditemukan 2 temuan (CWE-639, 862) di mana *record loader* aplikasi bergantung sepenuhnya pada input pengguna tanpa validasi otorisasi yang layak, misalnya pada `admin_area/index.php` baris 519.

Persistensi & Dampak: Kerentanan ini tidak bersifat sementara; tanpa perbaikan *source code* (implementasi *Prepared Statements* dan sanitasi *input*), aplikasi secara permanen membuka akses bagi penyerang untuk mengeksploitasi sistem kapan saja tanpa perlu menanamkan *malware* biner di sisi *server*. Vektor ini menjadi celah utama bagi pelaku untuk melakukan aktivitas pasca-eksploitasi seperti *Data Exfiltration* secara *real-time*.

2.4 Penilaian Risiko (Risk Assessment)

Evaluasi potensi risiko yang ditimbulkan dari insiden terhadap organisasi, berdasarkan dampak dan kemungkinan eksploitasi lanjutan pada aset yang terdampak.

A. Kritikalitas Aset (Asset Criticality) Server `dibishop.duckdns.org` merupakan server *Production* (bukan sekadar *staging*) yang menyimpan data pelanggan dan memproses transaksi *e-commerce*. Tingkat kritikalitas aset ini adalah **Sangat Tinggi (Critical)**, sehingga setiap gangguan akan berdampak langsung pada operasional dan reputasi bisnis.

B. Dampak pada CIA Triad

- **Dampak pada Confidentiality (Kerahasiaan):** Kerahasiaan data hancur total (*High Impact*). Keberadaan 52 celah SQL Injection, kredensial *hardcoded* di `db.php`, tereksposnya *file* `dibimbingshop.sql`, dan menyalanya fitur MySQL *General Query Log* (merekam *password plaintext*) memungkinkan penyerang mengekstrak seluruh data sensitif pelanggan (PII) tanpa hambatan.

- **Dampak pada Integrity (Integritas):** Terancam signifikan (*High Impact*). Melalui kerentanan SQLi dan Stored XSS, penyerang memiliki kemampuan untuk memodifikasi, menghapus, atau memanipulasi data produk, transaksi, dan akun pengguna secara sepihak.
- **Dampak pada Availability (Ketersediaan):** Sangat rentan (*High Impact*). Ketiadaan kontrol keamanan dasar seperti UFW (Firewall) yang mati dan absennya Fail2ban membiarkan serangan masif seperti SSH *Brute-Force* dari Vietnam menguras *resource* server (potensi *Denial of Service*), serta membuka jalan bagi RCE yang dapat menghapus data sistem.

C. Evaluasi Risiko dan Lateral Movement

- **Risiko Jangka Pendek:** Terjadinya *Data Breach* massal secara instan, pencurian sesi (*session hijacking*) pelanggan melalui XSS, dan pengambilalihan kendali server secara penuh (*Server Takeover*) jika eksploitasi LFI/RCE dari IP Meksiko berhasil.
- **Risiko Jangka Panjang:** Kerugian finansial akibat denda kepatuhan (*compliance*), hancurnya reputasi *e-commerce* di mata pelanggan, serta potensi server dijadikan *zombie/botnet* untuk menyerang institusi lain karena pertahanan *host* yang lumpuh.
- **Potensi Lateral Movement:** Sangat Tinggi. Dengan tereksposnya direktori `.git` dan diizinkannya `PermitRootLogin` pada SSH, penyerang yang berhasil masuk dapat dengan mudah memanen kunci SSH atau kredensial internal lainnya untuk melompat ke server *database* atau segmen jaringan internal lainnya secara leluasa.

Temuan	Dampak	CVSS	Severity
SQL Injection	<i>Dump DB & Manipulasi Transaksi</i>	9.8	Critical
Eksplorasi LFI/RCE (Web Scan)	Pengambilalihan Server (<i>Takeover</i>)	9.8	Critical
Hardcoded DB Credentials	Akses Langsung ke Database Internal	9.8	Critical
MySQL <i>General Query Log</i> Aktif	Kebocoran Kredensial <i>Plaintext</i>	7.5	High
UFW Nonaktif & Missing Fail2ban	Server terekspos serangan otomatis	7.5	High
Exposed <code>.git</code> & <i>Directory Listing</i>	Kebocoran <i>Source Code</i>	7.5	High

SSH <i>Insecure Config</i>	Akses <i>Root</i> terbuka	7.5	High
Stored XSS	Pencurian <i>Cookie</i> pengguna	6.4	Medium

Table 4. Penilaian Risiko dan Severity Temuan

2.5 Analisis Aktivitas Pasca-Eksploitasi

Analisis terhadap tindakan pencegahan dan pemulihan sistem untuk menghentikan aktivitas berbahaya serta rekomendasi untuk memperkuat postur keamanan agar tidak terjadi eksploitasi di masa depan.

1. Incident Response (Containment) Tindakan segera yang dilakukan untuk memutus akses penyerang:

- Mengisolasi *server* `dibishop.duckdns.org` dari trafik publik dengan mengaktifkan UFW dan menutup *port* yang tidak perlu.
- Menghentikan layanan MySQL *General Query Log* untuk mencegah kebocoran data pelanggan lebih lanjut.
- Melakukan *reset* terhadap kredensial *database* yang sebelumnya terekspos dalam bentuk *plaintext* di `db.php`.

2. Rekomendasi Hardening

- **Network Hardening:** Menginstal dan mengonfigurasi Fail2ban untuk melakukan *auto-blocking* terhadap IP yang melakukan *brute-force* SSH.
- **Application Hardening:** Melakukan *patching* kode secara menyeluruh, khususnya pada 52 titik celah SQL Injection dengan implementasi *Prepared Statements* (PDO).
- **System Hardening:** Menghapus akses *root* SSH secara langsung (`PermitRootLogin no`) dan menerapkan otentikasi berbasis kunci (SSH *Key-based authentication*).

3. Mapping ke MITRE ATT&CK

Phase	Technique	Evidence
Initial Access	T1595 (Active Scanning)	<i>Web Fuzzing</i> & Enumerasi direktori dari IP eksternal.
Initial Access	T1110 (Brute Force)	Log Wazuh <i>authentication_failed</i> pada layanan SSH

Execution	T1190 (Exploit Public App)	<i>Payload</i> LFI/RCE (pearcmd.php) yang terdeteksi di log web.
Credential Access	T1552 (Unsecured Credentials)	<i>Password</i> database <i>plaintext</i> ditemukan di db.php.
Exfiltration	T1534 (Internal Spearphishing/Data)	Risiko kebocoran <i>database</i> via log general_log MySQL.

III. KESIMPULAN DAN SARAN

3.1 Kesimpulan

Berdasarkan investigasi forensik digital dan asesmen keamanan pada infrastruktur dibishop.duckdns.org, disimpulkan bahwa sistem berada dalam status **Kritikal**. Keamanan infrastruktur terbukti sangat rendah akibat ketiadaan kontrol pertahanan dasar (*Missing Security Controls*), yakni tidak aktifnya *firewall* (UFW) dan ketiadaan sistem anti-brute-force (Fail2ban).

Penyerang luar telah menunjukkan intensitas serangan yang tinggi melalui aktivitas *scanning* (IP AS), *brute-force* SSH (IP Vietnam), dan upaya eksploitasi RCE (IP Meksiko). Kondisi ini diperparah dengan temuan 84 kerentanan aplikasi (52 di antaranya SQL Injection tingkat *Critical*), tereksposnya kredensial *database* dalam file [db.php](#), serta miskonfigurasi fatal pada MySQL *General Query Log* yang merekam data sensitif pengguna secara *plaintext*. Sistem saat ini sangat rentan terhadap *Data Breach* massal dan pengambilalihan kendali penuh oleh penyerang.

3.2 Saran

Untuk memitigasi insiden dan mencegah eksploitasi di masa depan, direkomendasikan langkah-langkah berikut:

- **Teknis (Hardening & Mitigation):**
 - **Perkuat Perimeter:** Segera aktifkan UFW dan batasi akses masuk hanya pada *port* yang krusial. Instal dan konfigurasikan Fail2ban untuk memblokir IP yang melakukan *brute-force* secara otomatis.
 - **Patching Aplikasi:** Prioritaskan perbaikan ke-52 temuan SQL Injection dengan beralih ke *Prepared Statements* (PDO) dan implementasikan sanitasi *input* yang ketat (seperti [htmlspecialchars\(\)](#)) untuk menutup celah XSS.
 - **Konfigurasi Sistem:** Ubah akses SSH ke *Key-based authentication* dan nonaktifkan [PermitRootLogin](#). Matikan fitur *General Query Log* pada MySQL dan hapus *file* log sensitif tersebut dari *server*.
 - **Sensitive Data Protection:** Pindahkan kredensial *database* dari [db.php](#) ke *Environment Variables* ([.env](#)) dan hapus repositori [.git](#) yang terekspos ke publik.
- **Non-Teknis (Policy & Training):**
 - **Audit Berkala:** Terapkan pemindaian SAST secara rutin dalam *pipeline* CI/CD untuk memastikan kerentanan baru terdeteksi sebelum aplikasi di-*deploy*.

- **Pendidikan Keamanan:** Memberikan pelatihan *Secure Coding* kepada tim pengembang untuk mencegah introduksi celah keamanan (seperti *hardcoded credentials*) di masa mendatang.
- **Dokumentasi:** Memperbarui prosedur operasional standar (SOP) untuk konfigurasi *server* agar tidak ada layanan yang aktif dengan konfigurasi *default* yang tidak aman.

LAMPIRAN

Lampiran 1. Log Aktivitas Brute Force

```
{ "_index": "wazuh-alerts-4.x-2026.05.19", "_id": "FWk2P54B9k8k-Of27mu1", "_version": 1, "_score": null, "_source": { "predecoder": { "hostname": "srv974671", "program_name": "sshd", "timestamp": "May 19 07:50:21" }, "agent": { "name": "srv974671", "id": "000" }, "previous_output": "May 19 07:50:17 srv974671 sshd[852383]: Invalid user shipping from 27.79.44.33 port 48200\nMay 19 07:50:17 srv974671 sshd[852386]: Invalid user vyatta from 27.79.44.33 port 48214\nMay 19 07:49:35 srv974671 sshd[852367]: Failed password for invalid user admin from 27.79.44.33 port 43008 ssh2\nMay 19 07:49:32 srv974671 sshd[852367]: Invalid user admin from 27.79.44.33 port 43008\nMay 19 07:49:25 srv974671 sshd[852362]: Failed password for invalid user brenda from 27.79.44.33 port 43004 ssh2\nMay 19 07:49:23 srv974671 sshd[852362]: Invalid user brenda from 27.79.44.33 port 43004\nMay 19 07:49:10 srv974671 sshd[852357]: Failed password for invalid user webadmin from 27.79.44.33 port 46340 ssh2", "data": { "srcuser": "vyatta", "srcip": "27.79.44.33" }, "manager": { "name": "srv974671" }, "rule": { "mail": false, "level": 10, "hipaa": [ "164.312.b" ], "pci_dss": [ "11.4", "10.2.4", "10.2.5" ], "tsc": [ "CC6.1", "CC6.8", "CC7.2", "CC7.3" ], "description": "sshd: brute force trying to get access to the system. Non existent user.", "groups": [ "syslog", "sshd", "authentication_failures" ], "nist_800_53": [ "SI.4", "AU.14", "AC.7" ], "frequency": 8, "gdpr": [ "IV_35.7.d", "IV_32.2" ], "firedtimes": 25, "mitre": { "technique": [ "Brute Force" ], "id": [ "T1110" ], "tactic": [ "Credential Access" ] }, "id": "5712" }, "decoder": { "parent": "sshd", "name": "sshd" }, "full_log": "May 19 07:50:21 srv974671 sshd[852386]: Failed password for invalid user vyatta from 27.79.44.33 port 48214 ssh2", "input": { "type": "log" }, "location": "journald", "id": "1779177022.854748", "GeoLocation": { "country_name": "Vietnam", "location": { "lon": 106, "lat": 16 } }, "timestamp": "2026-05-19T07:50:22.308+0000", "fields": { "timestamp": [ "2026-05-19T07:50:22.308Z" ] }, "highlight": { "rule.mitre.technique": [ "@opensearch-dashboards-highlighted-field@Brute Force@opensearch-dashboards-highlighted-field@" ], "data.srcip": [ "@opensearch-dashboards-highlighted-field@27.79.44.33@opensearch-dashboards-highlighted-field@" ] }, "sort": [ 1779177022308 ] }
```

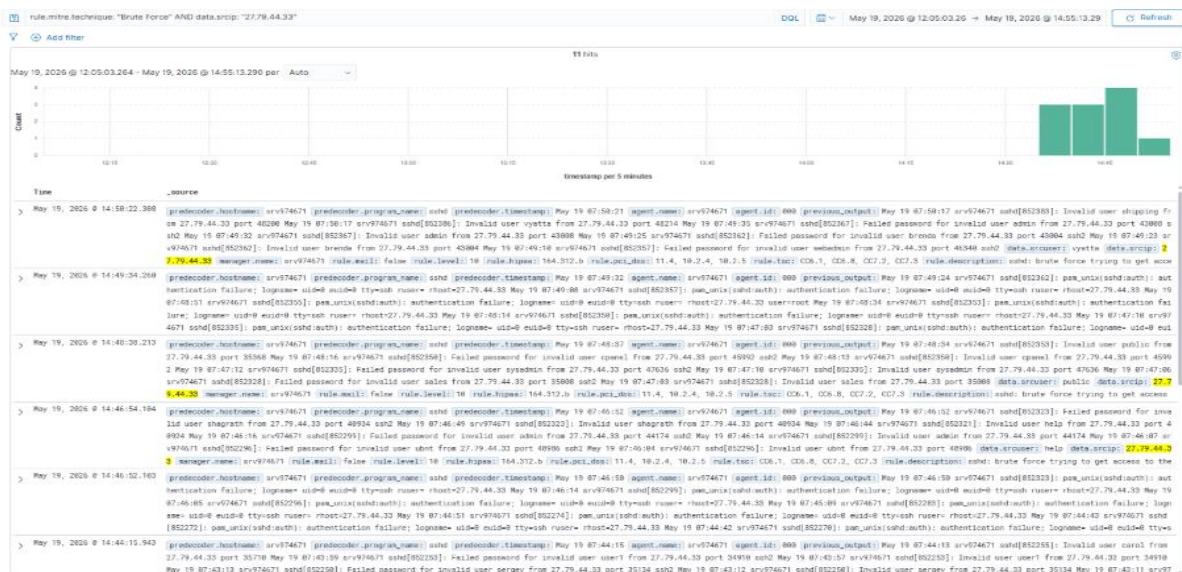


Figure 1. ssh_brute_force

Lampiran 2. Web Vulneability Scanning / RCE

```
{ "_index": "wazuh-alerts-4.x-2026.05.17", "_id": "92liN54B9k8k-Of2tl1K", "_version": 1, "_score":
null, "_source": { "input": { "type": "log" }, "agent": { "name": "srv974671", "id": "000" },
"previous_output": "200.23.126.85 - - [18/May/2026:02:21:13 +0700] \"GET
/index.php?s=/index/\\\\think\\\\app/vokefunction&function=call_user_func_array&vars[0]=md5&vars[1
][]=Hello HTTP/1.1\" 404 490 \\\"-\\\" \\\"libredtail-http\\\"\\n200.23.126.85 - - [18/May/2026:02:21:12 +0700]
\\\"GET /app/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php HTTP/1.1\" 404 490 \\\"-\\\" \\\"libredtail-
http\\\"\\n200.23.126.85 - - [18/May/2026:02:21:11 +0700] \\\"GET
/apps/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php HTTP/1.1\" 404 490 \\\"-\\\" \\\"libredtail-
http\\\"\\n200.23.126.85 - - [18/May/2026:02:21:09 +0700] \\\"GET
/public/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php HTTP/1.1\" 404 490 \\\"-\\\" \\\"libredtail-
http\\\"\\n200.23.126.85 - - [18/May/2026:02:21:09 +0700] \\\"GET
/panel/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php HTTP/1.1\" 404 490 \\\"-\\\" \\\"libredtail-
http\\\"\\n200.23.126.85 - - [18/May/2026:02:21:06 +0700] \\\"GET
/backup/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php HTTP/1.1\" 404 490 \\\"-\\\" \\\"libredtail-
http\\\"\\n200.23.126.85 - - [18/May/2026:02:21:08 +0700] \\\"GET
/workspace/drupal/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php HTTP/1.1\" 404 490 \\\"-\\\"
\\\"libredtail-http\\\"\\n200.23.126.85 - - [18/May/2026:02:21:07 +0700] \\\"GET
/blog/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php HTTP/1.1\" 404 490 \\\"-\\\" \\\"libredtail-
http\\\"\\n200.23.126.85 - - [18/May/2026:02:21:05 +0700] \\\"GET
/admin/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php HTTP/1.1\" 404 490 \\\"-\\\" \\\"libredtail-
http\\\"\\n200.23.126.85 - - [18/May/2026:02:21:04 +0700] \\\"GET
/crm/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php HTTP/1.1\" 404 490 \\\"-\\\" \\\"libredtail-
http\\\"\\n200.23.126.85 - - [18/May/2026:02:21:03 +0700] \\\"GET
/cms/vendor/phpunit/phpunit/src/Util/PHP/eval-stdin.php HTTP/1.1\" 404 490 \\\"-\\\" \\\"libredtail-http\\\"\",
"data": { "protocol": "GET", "srcip": "200.23.126.85", "id": "404", "url":
"/public/index.php?s=/index/\\\\think\\\\app/vokefunction&function=call_user_func_array&vars[0]=md5
&vars[1][]=Hello" }, "manager": { "name": "srv974671" }, "rule": { "firedtimes": 3, "mail": false,
"level": 10, "pci_dss": [ "6.5", "11.4" ], "tsc": [ "CC6.6", "CC7.1", "CC8.1", "CC6.1", "CC6.8",
"CC7.2", "CC7.3" ], "description": "Multiple web server 400 error codes from same source ip.",
"groups": [ "web", "accesslog", "web_scan", "recon" ], "mitre": { "technique": [ "Vulnerability
Scanning" ], "id": [ "T1595.002" ], "tactic": [ "Reconnaissance" ] }, "id": "31151", "nist_800_53": [
"SA.11", "SI.4" ], "frequency": 14, "gdpr": [ "IV_35.7.d" ] }, "location": "/var/log/apache2/access.log",
"decoder": { "name": "web-accesslog" }, "id": "1779045674.287598", "GeoLocation": {
"country_name": "Mexico", "location": { "lon": -99.0111, "lat": 19.4371 } }, "full_log": "200.23.126.85 - -
[18/May/2026:02:21:13 +0700] \"GET

/public/index.php?s=/index/\\\\think\\\\app/vokefunction&function=call_user_func_array&vars[0]=md5
&vars[1][]=Hello HTTP/1.1\" 404 490 \\\"-\\\" \\\"libredtail-http\\\"\", "timestamp": "2026-05-
17T19:21:14.311+0000" }, "fields": { "timestamp": [ "2026-05-17T19:21:14.311Z" ] }, "highlight": {
"data.srcip": [ "@opensearch-dashboards-highlighted-field@200.23.126.85@opensearch-dashboards-
highlighted-field@" ] }, "sort": [ 1779045674311 ] }
```



Lampiran 3. Fuzzing

```
{ "_index": "wazuh-alerts-4.x-2026.05.23", "_id": "LG6sUp4BMTk_1XDJEwdT", "_version": 1,
  "_score": null, "_source": { "input": { "type": "log" }, "agent": { "name": "srv974671", "id": "000" },
  "manager": { "name": "srv974671" }, "data": { "protocol": "GET", "srcip": "64.23.189.99", "id":
  "404", "url": "/manual" }, "rule": { "firedtimes": 287, "mail": false, "level": 5, "pci_dss": [ "6.5",
  "11.4" ], "tsc": [ "CC6.6", "CC7.1", "CC8.1", "CC6.1", "CC6.8", "CC7.2", "CC7.3" ], "description":
  "Web server 400 error code.", "groups": [ "web", "accesslog", "attack" ], "id": "31101",
  "nist_800_53": [ "SA.11", "SI.4" ], "gdpr": [ "IV_35.7.d" ] }, "location": "/var/log/apache2/access.log",
  "decoder": { "name": "web-accesslog" }, "id": "1779503466.232995", "GeoLocation": {
  "country_name": "United States", "location": { "lon": -97.822, "lat": 37.751 } }, "full_log":
  "64.23.189.99 - - [23/May/2026:09:31:06 +0700] \"GET /manual HTTP/1.1\" 404 435 \"-\" \"Mozilla/5.0
  (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/121.0 Safari/537.36\"",
  "timestamp": "2026-05-23T02:31:06.554+0000" }, "fields": { "timestamp": [ "2026-05-
  23T02:31:06.554Z" ] }, "highlight": { "data.srcip": [ "@opensearch-dashboards-highlighted-
  field@64.23.189.99@opensearch-dashboards-highlighted-field@" ] }, "sort": [ 1779503466554 ] }
```

Lampiran 4. MySql general query log

Variable_name	Value
general_log	ON
general_log_file	/var/lib/mysql/srv974671.log

Figure 3. mysql_general_log

Lampiran 5. Status Firewall UFW

```
analyst@srv974671:/var/www/dibimbingshop/customer$ cat /etc/ufw/ufw.conf 2>/dev/null | grep -i "ENABLED"  
ENABLED=no
```

Figure 4. Status Firewall UFW

Lampiran 6. Harcoded Credential

```
/var/www/dibimbingshop/customer/includes/db.php:$con = mysqli_connect("localhost","dibimbing-shop","password","dibimbing-shop");  
/var/www/dibimbingshop/includes/db.php:$con = mysqli_connect("localhost","dibimbing-shop","password","dibimbing-shop");  
/var/www/dibimbingshop/admin_area/includes/db.php:$con = mysqli_connect("localhost","dibimbing-shop","password","dibimbing-shop");
```

Figure 5. Harcoded Credential

Lampiran 7 SAST Report

Report SAST

REFERENSI

Contoh template laporan Forensik

<https://docs.google.com/document/d/158pl0d3x08ABv3OZa76FsetjMFnYjhXZ/edit>

Catatan tambahan/Saran :**Kerangka berpikir Defense :**

Final project ini mencakup SIEM analysis + DFIR + mitigation, sehingga saran kerangka berpikir adalah:

- **1. Detect**
 - Mengidentifikasi alert awal SIEM, log anomali, atau indikasi insiden.
- **2. Analyze**
 - Menganalisis log lebih dalam (server, WAF, system logs, malware behaviour).
- **3. Correlate**
 - Menghubungkan semua artefak (SIEM, server logs, WAF, malware, traffic) → membentuk timeline.
- **4. Assess Impact**
 - Menilai risiko & besarnya dampak (CIA triad, asset criticality).
- **5. Respond / Containment**
 - Langkah untuk menghentikan aktivitas berbahaya.
- **6. Recommend / Hardening**
 - Rekomendasi jangka panjang, secure configuration, patching.

emplate Analisis SIEM :

Bagian	Isi Wajib
Event Description	Jelaskan log apa yang muncul
Indicator	IP, user, time, signature
Root Cause	Kenapa event terjadi
Attack Vector	Bagian mana yang digunakan attacker
Impact	CIA impact
Mitigation	Aksi jangka pendek
Long Term Defense	hardening & policy